

사내 생성형 AI 입력 보안·감사 게이트웨이

직원의 프롬프트를 부서별 정책으로 검사하고,
판정 근거까지 남기는 AI-Ready 통제 서비스

일시 | 2026.09.02-09.04

팀원 | 박영서, 신민서, 정한결, 조종원



발표 구성

문제에서 시작해
설계와 실행 계획까지

RULE DECIDES

AI SUGGESTS

HUMAN CONFIRMS

AGENDA

01-02 문제 정의

AI 사용 확산 · 민감정보 입력 · 통제 공백

03-04 해결 전략

요구사항 기능화 · 규칙 / AI / 사람 책임 분리

05-13 서비스 설계

아키텍처 · 판정 경로 · Use Case · User Flow · AI 검사기 · ERD

14-17 구현과 협업

직원·관리자 화면 · REST API · GitHub Flow

18-21 서비스와 확장

사용자·관리자 관점 · Demo · Roadmap · 역할 분담

문제 정의

업무 AI 확산이 만든
입력 보안의 공백

ADOPTION · DATA EXPOSURE · CONTROL GAP

01

- RULE DECIDES
- AI SUGGESTS
- HUMAN CONFIRMS

업무 AI 사용은 통제보다 빠르게 늘고 있습니다

사용자는 늘고 입력량은 폭증했지만, 개인 계정 기반의 Shadow AI는 여전히 남아 있습니다.

ADOPTION

3×

기업 내 GenAI 사용자

전년 대비 사용자 수 증가

PROMPT VOLUME

6×

기업당 프롬프트 입력

3,000 → 18,000건 / 월

SHADOW AI

47%

개인 AI 앱 사용

회사 정책 밖의 계정 사용

사용은 늘었지만, 통제는 늦었습니다.

개인 계정으로 입력되는 업무 데이터는 회사의 정책·감사 범위를 벗어납니다.

민감정보 전송은 이미 반복적으로 발생하고 있습니다

평균 기업에서 월 223건의 GenAI 데이터 정책 위반이 탐지됐으며, 전년 대비 2배 증가했습니다.

MONTHLY VIOLATIONS

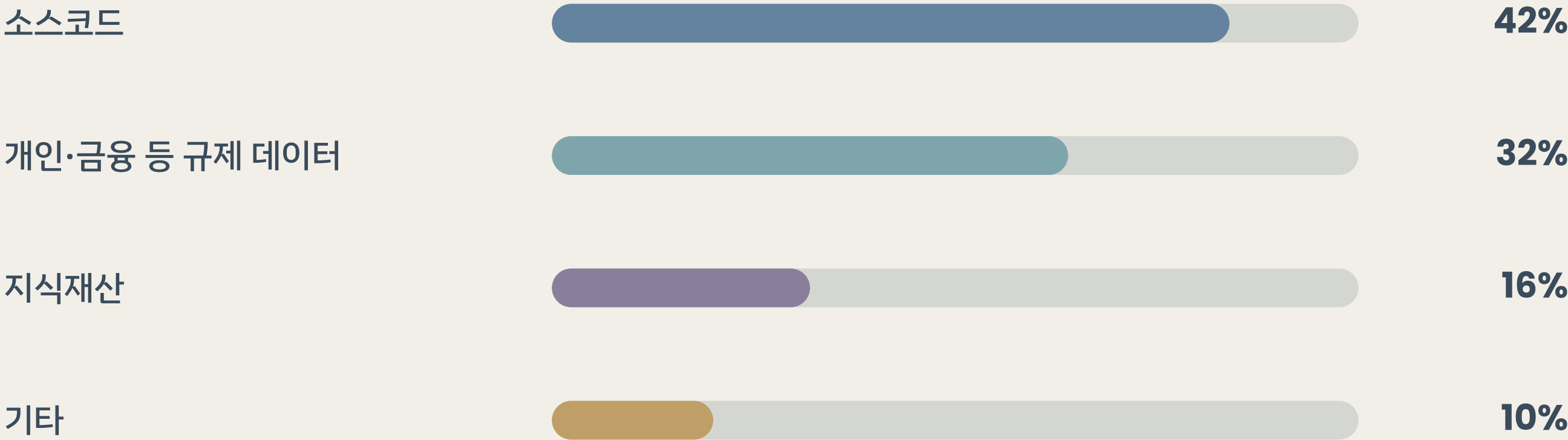
223건 / 월

평균 기업에서 탐지된
GenAI 데이터 정책 위반

전년 대비 2× 증가

정책 위반 데이터 유형

탐지된 GenAI 데이터 정책 위반 기준



50%

강제 가능한 GenAI 데이터 보호 정책이 없는 기업
사용자 주의만으로는 입력 단계의 유출을 막기 어렵습니다.

따라서 전면 차단이 아니라, 내용과 부서에 따른 세분화된 통제가 필요합니다.

해결 전략

위험도에 따라 나누는
네 가지 안전한 경로

REQUIREMENT → FEATURE · RULE / AI / HUMAN

02

- RULE DECIDES
- AI SUGGESTS
- HUMAN CONFIRMS

5가지 문제를 통제 기능으로 연결했습니다

각 기능은 탐지에서 끝나지 않고
전송 결과와 감사 기록까지 만듭니다.

5

문제 → 기능 → 작동 결과

REQUIREMENT		SERVICE FEATURE / OPERATION
01	민감정보가 그대로 입력된다	REGEX 탐지 · 자동 마스킹 전화번호·주민번호 등을 치환한 뒤 전송
02	부서마다 허용 범위가 다르다	부서 ↔ 정책 N:M 매핑 사용자 부서에 적용된 규칙만 로딩
03	맥락형 기밀은 패턴으로 못 잡는다	AiInspector 비동기 후보 제안 202로 접수하고 AI 후보를 비동기로 생성
04	최종 책임은 사람이 져야 한다	보안 담당자 ACCEPT / REJECT 담당자와 검토 시각을 함께 저장
05	사고 후 소명할 근거가 필요하다	정책 스냅샷 · 판정 근거 보존 당시 정책·RULE·AI 근거를 스냅샷으로 보존

규칙은 결정하고, AI는 제안하며, 사람이 최종 확정합니다

세 주체의 권한을 분리해 AI 오판이 곧바로 최종 판정이 되는 것을 막습니다.



권한 경계는 데이터로 강제됩니다

AI 응답 스키마에는 최종 decision이 없고, 사람의 확정은 reviewStatus·reviewedBy·reviewedAt과 함께 별도로 기록됩니다.

서비스 설계

정책이 먼저 움직이고
판단 근거가 남는 구조

ARCHITECTURE · PIPELINE · LLM BENCHMARK · USE CASE · ERD

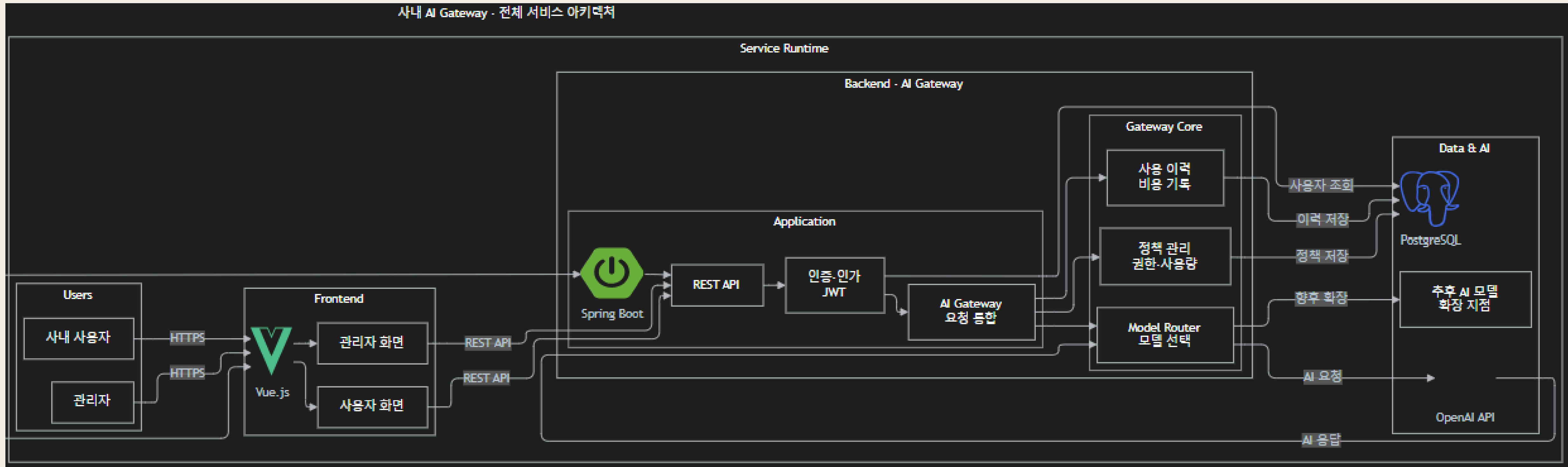
03

- RULE DECIDES
- AI SUGGESTS
- HUMAN CONFIRMS

AI보다 먼저, 정책이 움직입니다

프론트는 AI를 직접 호출하지 않습니다. 모든 요청은 Spring Boot의 정책 검사 경로를 통과합니다.

사내 AI Gateway - 전체 서비스 아키텍처



01 FRONTEND

Vue 3 화면

사용자·관리자 화면은 AI를 직접 호출하지 않고 REST로만 요청한다.



02 APPLICATION

Spring Boot

REST API와 JWT 인증을 지나 모든 요청이 게이트웨이로 모인다.



03 GATEWAY CORE

정책 검사·라우팅

부서 정책과 규칙으로 판정하고 사용 이력과 비용을 기록한다.



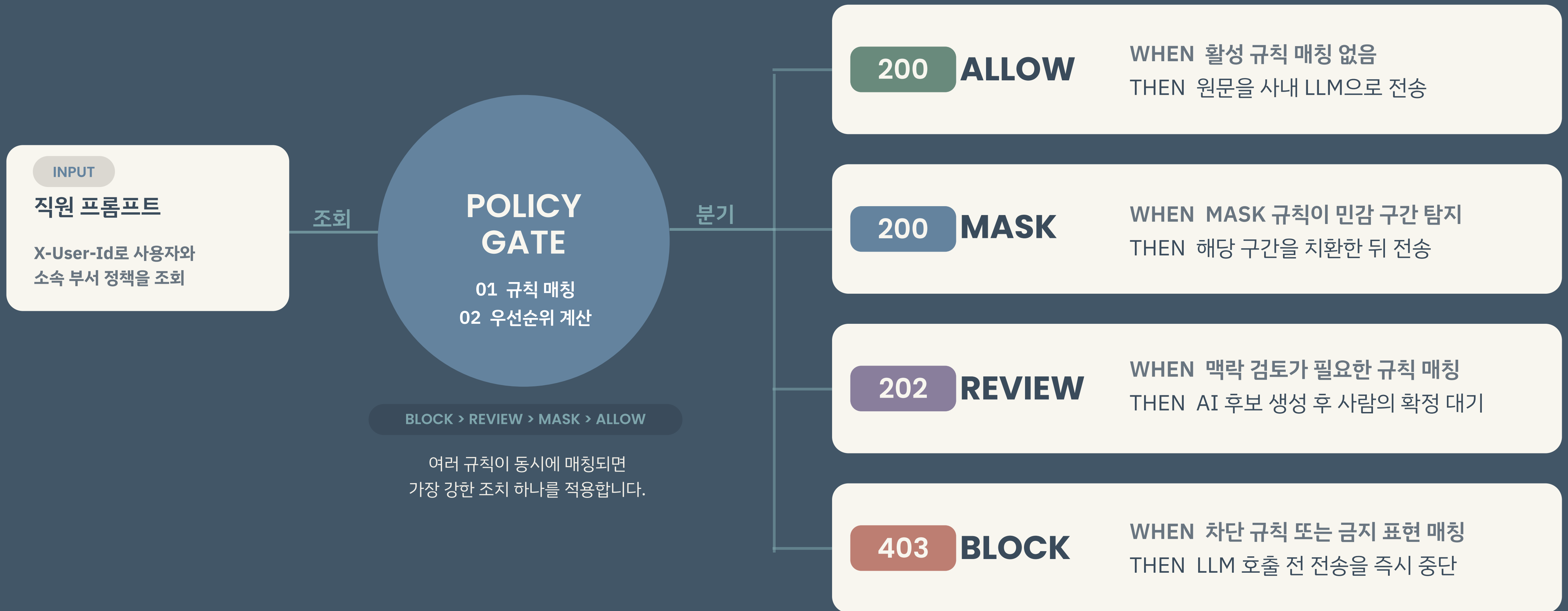
04 DATA & AI

PostgreSQL · LLM

판정 근거는 DB에 남고, 모델 호출은 교체 가능한 확장 지점 뒤에 둔다.

정책 게이트는 매칭 결과를 네 가지 실행 경로로 분기합니다

같은 프롬프트라도 적용 규칙과 위험도에 따라 전송 방식과 HTTP 응답이 달라집니다.



누가 요청하고, 누가 판정하며, 누가 확정하는가

원본 Use-Case 다이어그램을 중심으로 역할과 결정 경계를 함께 읽을 수 있도록 구성했습니다.

ACTOR · RESPONSIBILITY

01 직원

UC-01 제출·규칙 판정
UC-02 결과 확인·재제출 / UC-04 상태 조회

02 보안 담당자

UC-05 판정 이력 조회
UC-06 AI 후보 ACCEPT / REJECT

DECISION BOUNDARY

RULE 결정

→

AI 제안

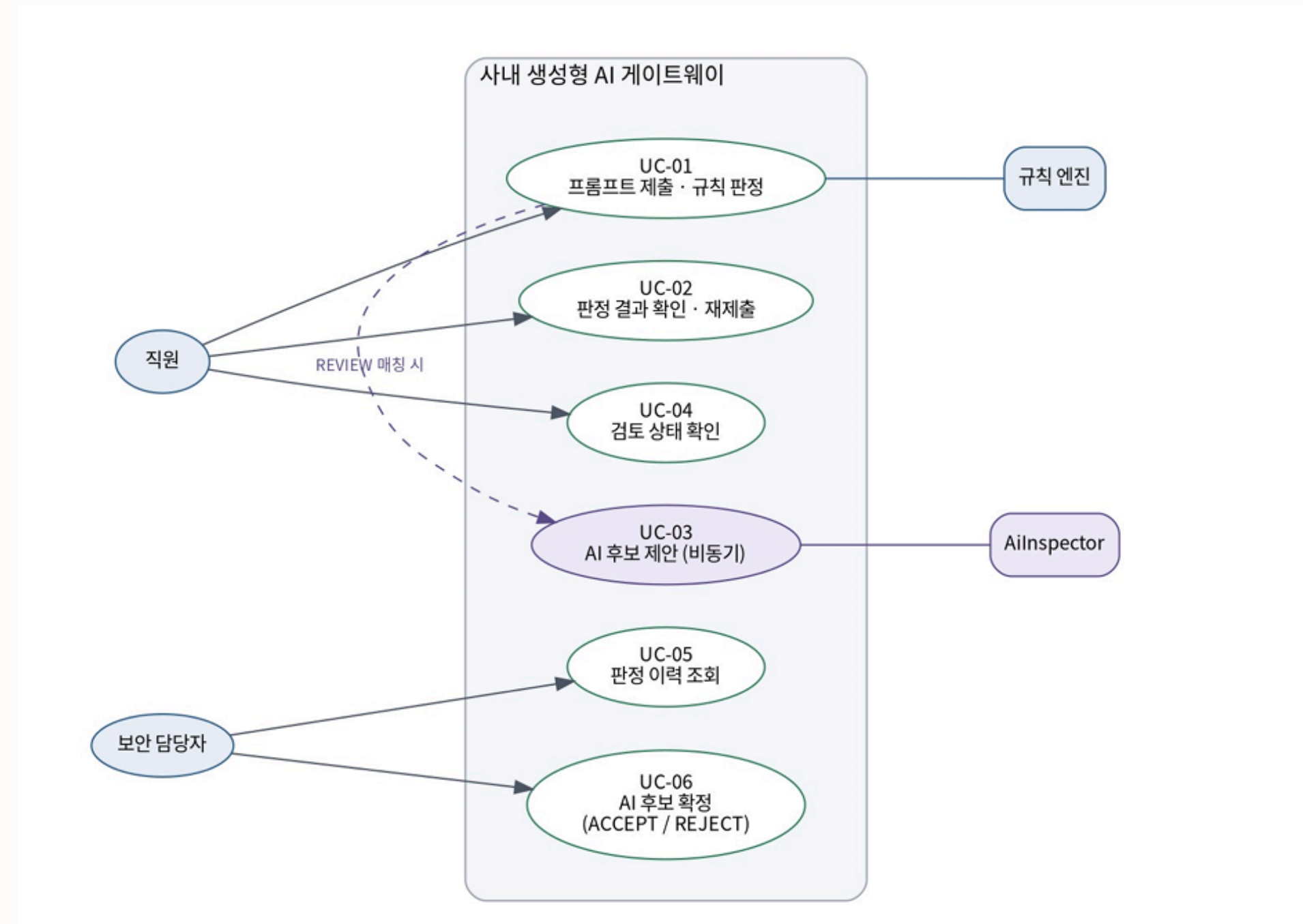
→

HUMAN 확정

AI 결과는 후보입니다. UC-06에서 보안 담당자가 확정해야 최종 판정이 되며, 확정자와 시점이 감사 이력에 남습니다.

ORIGINAL USE-CASE DIAGRAM

6 USE CASES



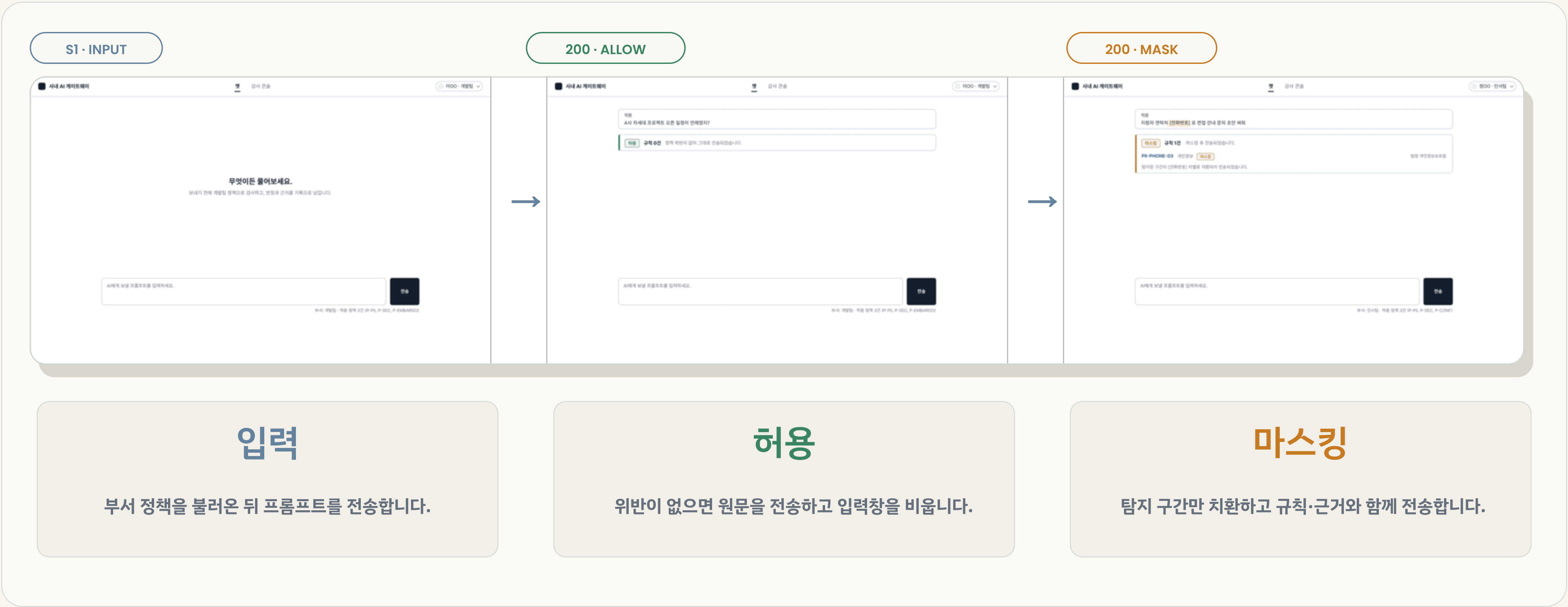
NEXT

UC-01 → 08A·08B 동기 화면 · UC-03 → 08C·09 비동기 검토 화면

원본 다이어그램 + 역할 해설

입력은 한 번, 동기 판정 결과는 즉시 갑니다

직원 화면에서 원문 전송과 치환 전송을 같은 구조로 비교합니다.



차단은 ‘왜 막혔는지’와 ‘언제 풀리는지’를 분리합니다

자격증명·개인정보 위반과 엠바고 위반의 복구 행동이 다릅니다.

403 · POLICY BLOCK

사내 AI 게이트웨이

첫

감사 콘솔

이OO · 개발팀

직원
이 예러 좀 봐줘. DB_URL=postgres://admin:p%40ss@10.0.3.21/prod 로 붙었는데
담당자 주민번호 900101-1234567 기준으로 조회하면 타임아웃 나

차단

규칙 2건 전송이 차단되었습니다. 내용을 수정한 뒤 재전송하세요.

SEC-DBURL-02 자격증명

차단

사규 정보보안규정 4.2
PII-RRN-01 개인정보

최소값

법령 개인정보보호법 제24조
차단된 항목을 제거하거나 대체한 뒤 다시 전송하세요.

이 예러 좀 봐줘. DB_URL=postgres://admin:p%40ss@10.0.3.21/prod 로 붙었는데
담당자 주민번호 900101-1234567 기준으로 조회하면 타임아웃 나

전송

입력장에 방금 입력한 내용이 그대로 남아 있습니다.

부서: 개발팀 · 적용 정책 3건 (P-PII, P-SEC, P-EMBARGO)

OR

403 · EMBARGO BLOCK

사내 AI 게이트웨이

첫

감사 콘솔

이OO · 개발팀

직원
2026 4Q 릴리스 백로그 정리 중 해줘. SKALA NOVA 런칭 일정이란
ATLAS 업데이트 항목이 섞여 있어

차단

규칙 1건 전송이 차단되었습니다.

EMB-NOVA-01 엠바고

차단

2026-09-20 해제

사규 홍보팀 엠바고 공지

2026-09-20부터 공개할 수 있는 내용입니다. 그때까지는 외부 AI로 보낼 수 없습니다.

2026 4Q 릴리스 백로그 정리 중 해줘. SKALA NOVA 런칭 일정이란
ATLAS 업데이트 항목이 섞여 있어

전송

해제일이 지난 표현은 같은 문장이어도 걸리지 않습니다.

부서: 개발팀 · 적용 정책 3건 (P-PII, P-SEC, P-EMBARGO)

민감정보 제거·대체 후 재전송

두 경우 모두 입력 원문은 보존하고, 규칙 ID · 의무 · 출처를 사용자에게 노출합니다.

해제일 이후 동일 문장 재전송 가능

검토가 필요한 요청만 비동기 경로로 전환됩니다

직원은 폴링 상태를 보고, AI 후보 뒤의 최종 결정은 보안 담당자가 확정합니다.

202 · POLLING

REVIEW · HUMAN DECISION

사내 AI 게이트웨이

검토 대기

검사 콘솔

김OO · 영업팀

직관

A사 차세대 프로젝트 오픈 일정이 언제였지?

검토 대기

규칙 1건

보안 검토가 필요한 내용입니다.

CONF-CLIENT-01

기밀

검토

사규 고객사 NDA 목록 v3

보안 검토 중

2초 경과 · 폴링 1회

2,000ms 간격 · 최대 30회

검토가 끝날 때까지 입력이 잠깁니다.

전송

부서: 영업팀 · 적용 정책 4건 (P-PII, P-SEC, P-CONF, P-EMBARGO)



사내 AI 게이트웨이

검토 대기

검사 콘솔

김OO · 영업팀

직관

A사 차세대 프로젝트 오픈 일정이 언제였지?

검토 대기

규칙 1건

보안 검토가 필요한 내용입니다.

CONF-CLIENT-01

기밀

검토

사규 고객사 NDA 목록 v3

검토 대기

검토 대기 (담당자 확정 필요)

아래는 AI가 제시한 후보입니다. 확정은 보안 담당자가 검사 콘솔에서 합니다.

CONF-CLIENT-PROJECT

기밀

제안됨

'A사 차세대 프로젝트 오픈 일정'이라는 서술이 계약 상대방과
미공개 일정을 동시에 특정함
▪ 고객사 NDA 목록 v3 — A사 — 비밀유지 2027.03까지, 일정 범위 포함
확인이 필요한 맥락 — 해당 일정이 대외 공개된 정보인지 확인 필요

확정 버튼은 이 화면에 없습니다. 담당자가 확정하면 새로고침으로 결과가 반영됩니다.

AI에게 보낼 프롬프트를 입력하세요.

전송

부서: 영업팀 · 적용 정책 4건 (P-PII, P-SEC, P-CONF, P-EMBARGO)

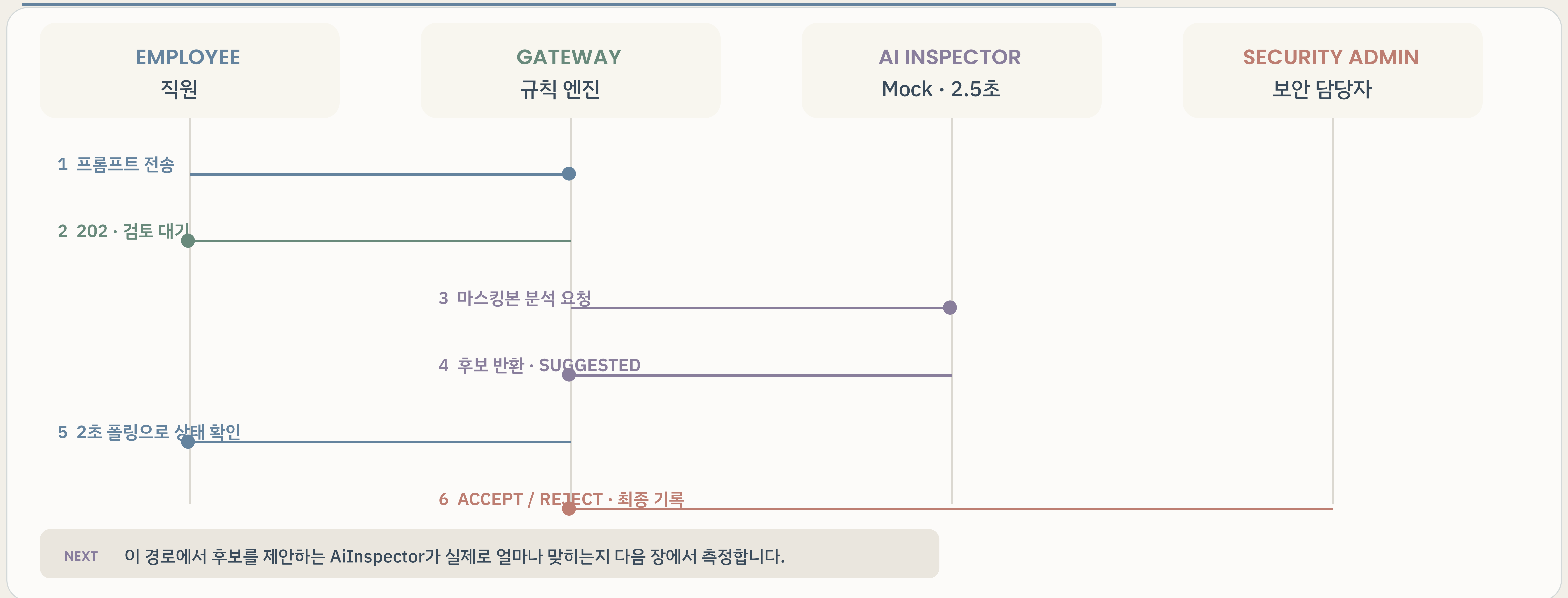
입력 잠금 · 2초 간격 · 최대 30회 폴링

AI 후보 제시 → 담당자 ACCEPT / REJECT → 재조회 반영

동기 판정과 비동기 검토의 경계를 화면 상태로 분리해, 사용자에게 현재 책임 주체를 명확히 보여줍니다.

AI가 늦어도 화면은 멈추지 않습니다

202 응답으로 접수와 결과 조회를 분리하고, 최종 결정은 보안 담당자가 수행합니다.



AI 응답에는 decision이 없습니다. 모든 후보는 SUGGESTED로 저장됩니다.

역할 경계는 코드가 아니라 구조로 강제했습니다

규칙이 결정하고 AI는 제안한다는 원칙을, 지킬 수밖에 없는 자리에 심었습니다.

AI 응답에 decision 필드를 두지 않았다

01

프롬프트로 금지하면 모델이 어길 수 있습니다.
응답 스키마에 결정 칸 자체가 없으면 어길 방법이 없습니다.

이 결정이 막는 것

AI 오판이 곧바로
최종 판정이 되는 일

9.4 입출력 스키마

규칙 판정에는 ACCEPT / REJECT를 두지 않았다

02

사람이 뒤집을 수 있는 것은 AI 후보뿐입니다. 정규식이 확정한
위반까지 재량으로 열면 통제 기록이 의미를 잃습니다.

이 결정이 막는 것

감사 기록이 재량으로
무력화되는 일

UC-05 / UC-06

확정은 폴링이 아니라 새로고침으로 본다

03

담당자가 언제 확정할지는 예측할 수 없습니다.
끝나지 않는 폴링은 서버만 때리고 화면은 계속 대기합니다.

이 결정이 막는 것

예측 불가능한 대기를
화면이 떠안는 일

UC-04

로컬 LLM 검사기는 얼마나 잡아내는가

08C · 09에서 본 검토(202) 경로에서 후보를 제안하는 그 AiInspector입니다. 실제 성능을 측정했습니다.

UC-03 · REVIEW 경로 · AiInspector

F1 · HOLDOUT

0.925

PRECISION

0.974

정밀도

RECALL

0.881

재현율

정상 66건 중 1건

1.5%

오탐률

문장당 · qwen2.5:7b

1.1s

지연

검증셋을 세 층으로 나눴다

튜닝한 셋으로 점수를 내면 학습 점수이지 성능이 아니다.

개발셋	326문장	기밀 124 · 정상 202	프롬프트 변형 선택
홀드아웃	111문장	기밀 42 · 정상 66	보고용 · 1회만 실행
메시지 단위	8건	여러 문장 혼합	실제 운영 형태

프롬프트 MD5를 파일에 박아 동결한다. 다르면 점수를 무효 처리한다.

프롬프트 개선 전후 · 같은 홀드아웃

셋이 다르면 비교가 안 된다. 같은 셋에 옛 프롬프트를 다시 돌렸다.

	정밀도	재현율	F1	오탐률
개선 전	0.885	0.511	0.648	4.5%
개선 후	0.974	0.822	0.892	1.5%

정밀도와 재현율이 함께 올랐다. 보통은 한쪽이 오르면 다른 쪽이 내려간다.

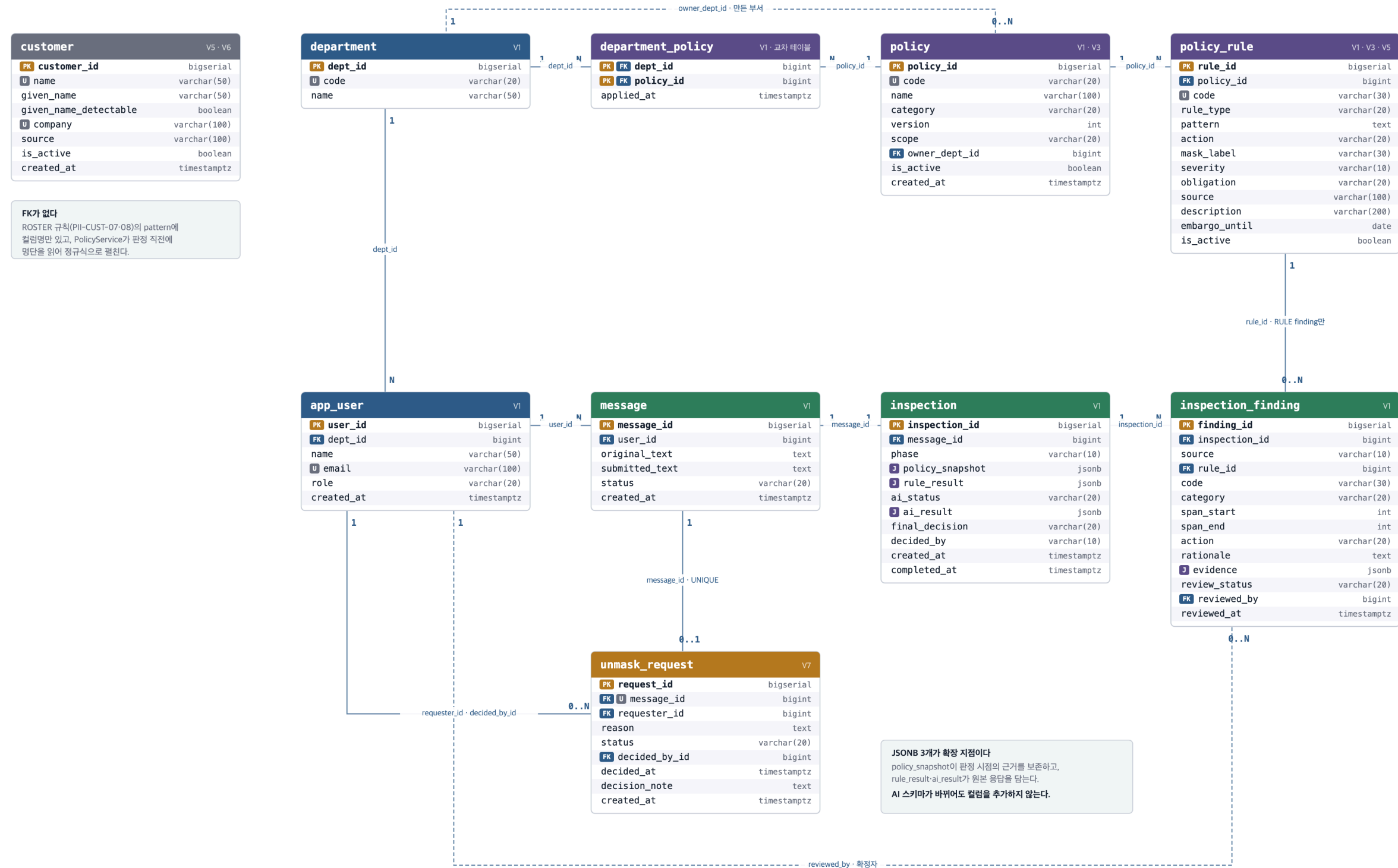
엔터티는 무엇을 지키려고 나뉘는지로 갈랐습니다

조직 · 계정 정책 판정 기록 사람 개입

ERD — 사내 생성형 AI 게이트웨이

테이블 10종 · 마이그레이션 V1~V7 기준 · 2026-09-03

■ 조직 · 계정 ■ 정책 ■ 판정 기록 ■ 사람 개입 ■ 참조 데이터 PK 기본키 FK 외래키 U UNIQUE J JSONB



기획서 6.5의 Future 엔티티(attachment · knowledge_source · policy_audit · ai_provider_config)는 DDL이 없어 그려지 않았다 — 논리 모델은 docs/erd.dbml에 있다. 생성: node docs/erd-build.mjs

조직 · 계정

department · app_user · customer

부서가 정책 적용의 단위입니다. 사용자는 부서를 통해서만 정책을 받으므로, 부서를 지우면 어떤 정책도 적용되지 않습니다.

정책

policy · policy_rule · department_policy

정책은 버전을 갖고, 규칙은 정책에 종속됩니다. 부서와의 연결만 교차 테이블로 빼서 정책 본문과 적용 범위를 따로 바꿀 수 있게 했습니다.

판정 기록

message · inspection · inspection_finding

원문과 전송본을 한 행에 나눠 담고, 판정과 근거를 각각 남깁니다. 판정은 요약, finding은 규칙별 증거입니다.

사람 개입

unmask_request

마스킹 해제만 요청과 승인을 분리했습니다. 사람이 정보를 다시 여는 행위는 판정 기록과 섞이면 안 되기 때문입니다.

관계마다 카디널리티를 정한 기준이 있습니다

엔터티를 나눈 것보다 어떻게 이었는지가 더 많은 것을 결정합니다.

department — app_user	1:N	사용자는 한 부서에만 속합니다. 검직을 허용하면 판정 시점에 어느 정책을 적용할지 결정할 수 없습니다.
department — policy	N:M	한 정책이 여러 부서에, 한 부서에 여러 정책. policy에 dept_id를 두면 같은 정책을 부서 수만큼 복제해야 합니다.
policy — policy_rule	1:N	규칙은 정책 밖에서 단독으로 존재하지 않습니다. 정책을 끄면 규칙도 함께 멈춰야 합니다.
message — inspection	1:N	지금은 INPUT 검사만 있어 사실상 1:1이지만, OUTPUT 검사를 붙일 자리를 남겨 1:N으로 뒀습니다.
inspection — inspection_finding	1:N	한 번의 판정에 여러 규칙이 걸립니다. 규칙별로 근거를 남겨야 나중에 소명이 됩니다.
policy_rule — inspection_finding	1:N nullable	AI 후보에는 참조할 규칙이 없습니다. nullable이 RULE과 AI 출처를 한 테이블에서 구분합니다.
app_user — inspection_finding	1:N reviewed_by	확정한 사람을 남기지 않으면 감사 기록이 성립하지 않습니다.
그 외 구조 결정	scope=GLOBAL은 매핑 없이 전사 적용 · 판정 근거는 JSONB 스냅샷으로 보존 · review_status 기본값 SUGGESTED	

구현과 협업

화면과 API, 그리고
3일을 버티는 협업 규칙

EMPLOYEE CHAT · AUDIT CONSOLE · REST API · GITHUB · TOOLING

04

- RULE DECIDES
- AI SUGGESTS
- HUMAN CONFIRMS

직원은 판정 이유를 보고 안전하게 다시 씁니다

SCR-01 /chat



ALLOW · MASK · BLOCK · REVIEW

현재 장면

전화번호 자동 마스킹

정00 · 인사팀



사내 AI 게이트웨이

무엇을 도와드릴까요?

적용 정책 · P-PII v3

지원자 연락처 정리해줘. 010-2345-6789 입니다

200 MASK

지원자 연락처 정리해줘. [전화번호] 입니다

PII-PHONE-03

LEGAL

사내 AI에 질문을 입력하세요

전송

원문 대신 마스킹된 본문만 전달됩니다.

AI 후보를 확인하고, 최종 판단을 기록합니다

판정 이력

부서 ▾

상태 ▾

기간 ▾

시각	사용자	부서	판정
14:22	김00	영업팀	REVIEW
14:19	이00	개발팀	BLOCK
14:05	정00	인사팀	MASK
13:58	이00	개발팀	ALLOW

INSPECTION #1042

PENDING_REVIEW

RULE / 규칙 결과

CONF-CLIENT-01

KEYWORD · REVIEW · MEDIUM

matchedKeyword / 차세대

AI / 후보

CONF-C-CLIENT-01 후보

미공개 고객사 프로젝트 일정으로
보입니다. 확인이 필요합니다.

ACCEPT

REJECT

FINAL

BLOCK

decided_by HUMAN · reviewed_by 김도현

11개 API가 판정·감사·해제 검토를 하나로 연결합니다

Base URL /api/v1
모든 요청 X-User-Id 필수

POST /messages

- 200 ALLOW · MASK
- 202 PENDING + Location
- 403 BLOCK · 판정 객체

202는 pollAfterMs 간격으로 조회
403 정책 BLOCK에는 error code가 없습니다.

명세서 기준 기능별 API

REFERENCE3 GET /departments GET /users GET /policies	HUMAN REVIEW1 PATCH /inspections/{id}/findings/{findingId}
INSPECTION3 POST /messages GET /inspections GET /inspections/{id}	UNMASK REVIEW4 POST /messages/{id}/unmask-request GET /messages/{id}/unmask-request GET /unmask-requests POST /unmask-requests/{id}/decision

CONTRACT RULES	
01 목록 응답 { items, page, size, total }	02 비동기 202 + Location + pollAfterMs
03 오류 구분 정책 403은 판정 / 권한 403은 code	04 공통 규칙 lowerCamelCase · UTC ISO-8601 · null 유지

빠르게 나누고, 안전하게 합칩니다

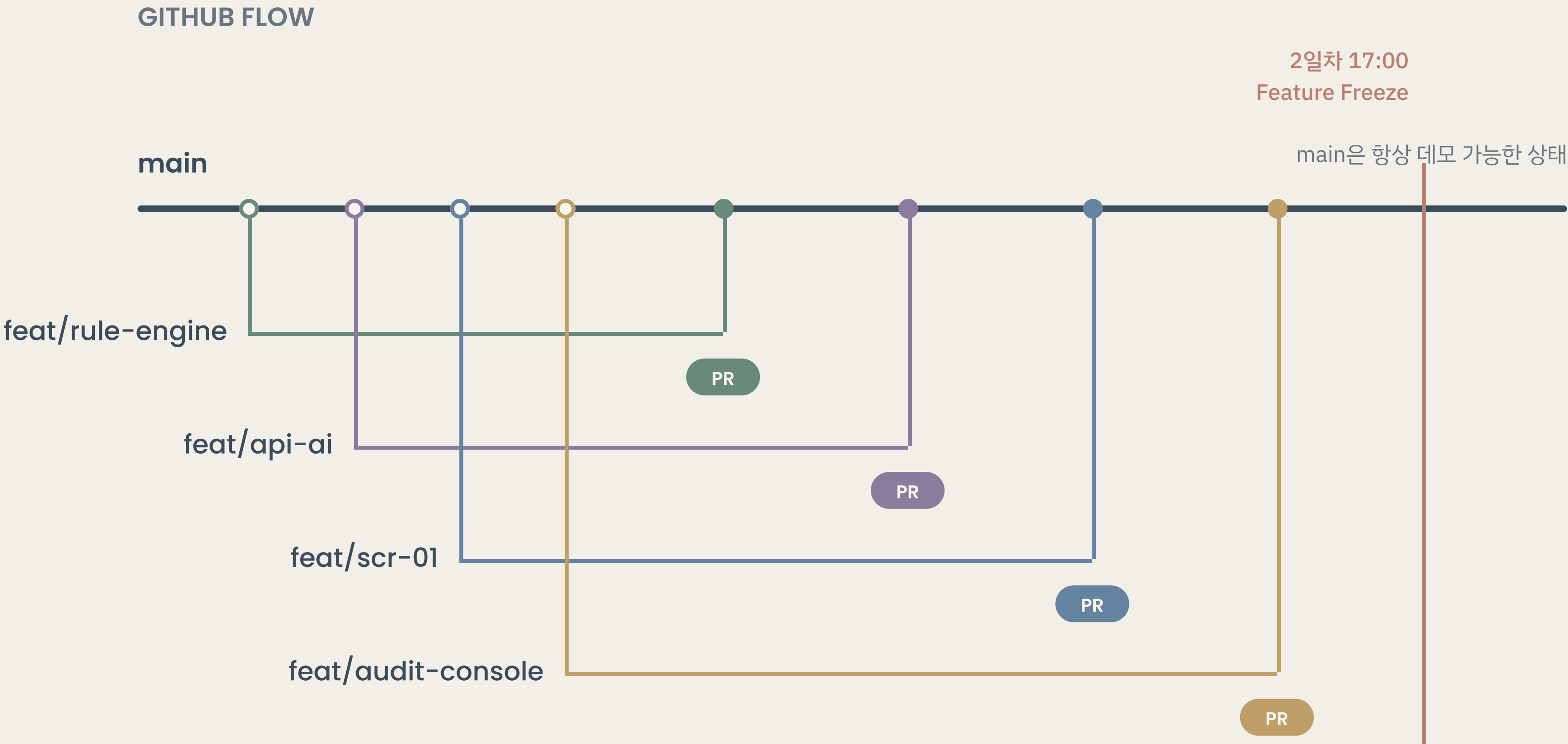
3일 프로젝트에서는 기능 수보다
main의 안정성이 더 중요합니다.

WHY GITHUB FLOW

3일 일정에 develop·release 브랜치까지 두면
머지 경로만 늘어납니다. main과 feat/* 둘로만
운영해 통합 지점을 하나로 유지했습니다.

MONOREPO

frontend/
backend/
docs/



feat/*는 main에서 갈라져 PR 리뷰를 거쳐 main으로만 돌아옵니다. develop · release 브랜치는 두지 않았습니다.

PR 1인 리뷰



2일차 17:00 Feature Freeze



버그 픽스만

서비스와 확장

완성된 기능과
그다음에 남긴 자리

DECISION ROUTES · TWO VIEWS · DEMO · ROADMAP · OWNERSHIP

05

- RULE DECIDES
- AI SUGGESTS
- HUMAN CONFIRMS

직원은 계속 쓰고, 관리자는 근거를 감사합니다



판정 능력과 AI 후보를 확인

- 01 부서 · 상태 · 기간으로 검색
- 02 RULE / AI 결과 분리 확인
- 03 AI 후보 ACCEPT / REJECT
- 04 decided_by · 정책 버전 기록

같은 설계가 네 가지 상황에서 다르게 작동합니다

A와 B는 통제를, C는 부서별 정책 차이를, D는 업무 지속성을 증명합니다.

A

개발팀

INPUT

DB 접속 문자열
+ 주민번호

RESULT

BLOCK

규칙 즉시 차단

B

영업팀

INPUT

A사 차세대
프로젝트 일정

RESULT

REVIEW

AI 후보 → 사람 확정

C

개발팀

INPUT

B와 완전히
같은 문장

RESULT

ALLOW

부서별 정책 차이

D

인사팀

INPUT

지원자
전화번호

RESULT

MASK

치환 후 업무 지속

작은 범위를 완성하고, 교체 가능한 AI 연결점을 남겼습니다

현재 구현과 향후 확장을 분리해 3일 범위 안에서 완성도를 확보했습니다.

NOW

정책·감사 흐름 완성

- REGEX 7종 · KEYWORD 3종
- 정책 4종 · 부서 N:M
- 감사 콘솔 ACCEPT / REJECT
- Mock AI · 2.5초 응답

NEXT

실제 AI 연결

- LlmAiInspector 교체
- 사내 호스팅 모델
- RAG 근거 문서 검색
- phase=OUTPUT 검사

LATER

운영 게이트웨이 확장

- 첨부파일 추출기
- 프롬프트 비용·효율 분석
- 정책 편집·버전 발행

역할명이 아니라 ‘완료할 산출물’로 나눴습니다

4명이 7개 역할을 겸임하되, 2일차 오전부터 병렬 작업이 가능하도록 축을 분리했습니다.

A 신민서

PM + AI

기획 범위 · Use Case
Figma · MockAiInspector



B 조종원

DA + BE

ERD · Flyway · JPA
REST 명세
발표자료



C 정한결

API + BE

REST 명세 · JSON 스키마
@Async · Review API



D 박영서

FE + DEVOPS

Vue 화면 · CI/CD
GitHub 세팅
E2E 통합 검증



AI를 막는 것이 아니라,
안전하게 쓸 수 있도록
통제합니다.

THANK YOU

사내 생성형 AI 입력 보안·감사 게이트웨이

SKALA · AI 웹 서비스 설계 MINI PROJECT · 4반 5조



VISIBLE CONTROL

RULE

AI

HUMAN

ALLOW · MASK · REVIEW · BLOCK